

[doc. web n. 9941780]
Provision of September 14, 2023
Register of provisions
No. 402 of September 14, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Ginevra Cerrina Feroni, Vice President,
Dr. Agostino Ghiglia and Attorney Guido Scorza,
members, and Dr. Claudio Filippi, Deputy
Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016 (hereinafter, "Regulation");

HAVING REGARD TO the Code regarding the protection of personal data, containing provisions for
the adaptation
of the national legal system to Regulation (EU) 2016/679 (Legislative Decree of June 30, 2003, No.
196, as
amended by Legislative Decree of August 10, 2018, No. 101, hereinafter "Code");

HAVING REGARD TO the complaint submitted on 12/5/2023 pursuant
to Article 77 of the Regulation by Mr. XX,
represented for the purposes of this proceeding
by Attorney XX, against Intesa Sanpaolo
S.p.a.;

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor's
Regulation No. 1/2000;

REPORTING Attorney Guido Scorza;

PREMISE

1. The complaint against the credit institution
and the investigative activity.
With notes dated 1/6/2022 and 12/5/2023, Mr. XX has
submitted a complaint to this Authority alleging that
he did not receive a response from Intesa
Sanpaolo S.p.a. (hereinafter "ISP" or "the bank" or
"the credit institution") to the request for access to
personal data concerning his minor child made
by the same complainant, in the exercise of his

parental authority, pursuant to Article 15 of the GDPR.

Following the invitation issued by the Office to
provide observations regarding the facts subject to
the complaint as well as to voluntarily comply with the
requests made by the complainant, the Bank, with a note dated
25/5/2023 (sent to the interested party and simultaneously
to this Authority), communicated the requested
information, specifying that the delay was
caused by "a mere operational error that occurred
in the management process of the original request"; in
particular, the Institute, in stating that it became

aware of the access request only after receiving the invitation to comply issued by the Authority, highlighted how the structure that oversees the receipt of communications at the certified email address of Intesa Sanpaolo, forwarded the request in question “to the relevant Branch [...] which, unfortunately, did not proceed with any direct response or the sending of the same” to the designated structure (Privacy Function) “for subsequent fulfillment”; in the same note, it is also specified that the Bank has provided that “the management of requests for the exercise of rights established by the Regulation, given the importance attributed to them, is carried out by the Privacy function in support of the Data Protection Officer. For this reason, also with a view to simplifying the methods of transmission of requests by interested parties and reducing processing times, the Bank has made available multiple channels for the submission of requests, including, in particular, the specifically designated email addresses dpo@intesasnpaolo.com or privacy@pec.intesasnpaolo.com directly monitored by the aforementioned function, reported in the Privacy section of the bank's website and in the customer information on the processing of personal data in the part relating to the exercise of a right by the interested parties.”

With a note dated 7/6/2023, the Office, based on the documentation on file and the elements acquired during the investigation, proceeded to notify Intesa Sanpaolo S.p.a. of the initiation of proceedings for the adoption of measures pursuant to Articles 58, paragraph 2, and 83 of the Regulation, in accordance with the provisions of Article 166, paragraph 5, of the Code, in relation to the violation of Articles 12 and 15 of the Regulation.

With the same note, the company was invited to submit defensive writings or documents or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, Law No. 689 of November 24, 1981).

With a note dated 30/06/2023, ISP submitted its defensive writings, which are fully referenced here, in which, emphasizing that “both at the level of the Company and as the Parent Company of the Intesa Sanpaolo banking group, it has always been committed to ensuring, for the interested parties, compliance with all regulatory provisions related to the exercise of rights (...)” – so much so that, “in 2022, the Bank received 5127 requests for the exercise of rights (of which 336 related to the exercise of the right of access), all duly fulfilled and regarding which no complaints have been received to date about the

omission or incomplete response provided to the interested parties” - it provided some clarifications and explanations.

In particular, it highlighted:

1. that it has adopted “a solid framework of internal procedures, operational instructions for the Staff regarding the processing of personal data in general and, specifically, the activities to be carried out for the correct management of requests for the exercise of rights by the interested parties” (documentation of which a copy has been produced); in particular, the document titled “Process Guide for Compliance Management – Management of the regulatory area Privacy Protection” contains “on page

12. An explicit reference is made reiterating that the instructions provided apply not only to requests related to the exercise of rights by the data subjects but also to requests (...) that contain words such as “Data Protection Authority”, “Privacy”, “GDPR” or “processing of personal data”. This instruction aims to submit any and all communications received by the Bank that contain even a mere reference to the legislation (...) to the specialized function responsible, thus avoiding that a partial management of the communication, or a misreading of the same, may result in a failure to respond, even if involuntary, to the exercise of a right by the data subjects or inadequately manage a report relevant to the protection of personal data; furthermore, “to strengthen the instructions outlined in the internal regulations, a publication has long been in place - on a quarterly basis - in the “News” section of the ABC Informative portal and in the “Last Minute” information of the HELP 4U portal - of a message directed to the Bank’s Personnel in order to periodically remind them of the essential elements for managing requests for the exercise of rights by the Data Subjects (external and internal regulations of reference, timelines, email addresses of the specialized structure responsible for the analysis and related management of the request)”; finally, “the document “Management Procedures for Communications Related to Privacy Issues” has been prepared, already shared during a meeting held on June 5 (before receiving the reported violation on June 7) with the structure of the Bank that manages the institutional certified email address of Intesa Sanpaolo (...) to which the original request for access to the personal data of the minor XX (...) was sent on April 21, 2022”; in the same, “reiterating what has already been indicated in the internal regulations previously summarized, indications have been provided to allow for better identification of potentially relevant requests in order to forward them promptly to the specialized (Privacy) function of the Bank, responsible for evaluating and responding to what has been received with particular reference to the exercise of rights by the data subjects”;

2. With reference to the specific case, “from the checks carried out following the communication received from your Authority on May 17, 2023 (...) it has been ascertained that the lack of response (...) was caused by an unintentional operational error that occurred in the process of relative management.” In particular, “once the personal data position of XX was identified, the original communication from lawyer XX was promptly sent to the relevant branch of establishment (...). Unfortunately, it did not carry out any subsequent processing or forwarding to the Privacy function”; that said, “fully aware of what is indicated in the recent Guidelines 01/2022 on the exercise of the right of access issued by the EDPB, as well as the considerations already expressed by your Authority in previous measures taken,” it is necessary to highlight again that “ISP has made available to customers ordinary email addresses and certified email (PEC) (...) expressly dedicated to the exercise of the rights of the data subjects and, more generally, to the submission of any issues related to the processing of personal data carried out by the Bank as the data controller (...); the general PEC address to which the original request for access was sent “receives about 2500-2700 daily communications with multiple contents and needs, which are deeply different from each other, and whose management competence belongs, consequently, to different internal structures, among which

may also be included the branches of establishment of the banking relationship related to the sender”;

3. In relation to the scope and severity of the violation that occurred, it must be considered “given the time elapsed since the original request (which was never followed up),” to be “extremely circumscribed and limited to the operational misunderstanding described (...), avoidable had the request been sent to the relevant addresses for managing requests for the exercise of rights by the data subjects”; in any case, “the conduct of Intesa Sanpaolo has always been characterized by maximum cooperation with the data subject and with the Data Protection Authority, providing during the procedure, responses, documents, and information in a timely manner (...)”; moreover, it is noted that, “following the response provided to lawyer XX on May 25, 2023, he sent, on May 29, 2023, on behalf of Mr. XX, a request to obtain a copy of the account statements (from the opening) of the current account held in the name of the minor son, based on the provisions established by the Consolidated Banking Act and the GDPR.” This request, “as a gesture of maximum cooperation, also considering the unfortunate incident that occurred previously,” was promptly responded to, and on June 1, 2023, “a copy of the requested account statement was provided to the interested party, without applying (...) the legally prescribed fees.”

2. The regulations regarding the protection of personal data. Article 12 of the Regulation states that “the data controller shall take appropriate measures to provide the data subject with all [...] the communications referred to in Articles 15 to 22 and Article 34 relating to the processing” (par. 1) and that “the data controller facilitates the exercise of the rights of the data subject pursuant to Articles 15 to 22” (par. 2). Paragraph 3 of the same article specifies that “the data controller provides the data subject with the

****Information regarding the action taken concerning a request pursuant to Articles 15 to 22****

without undue delay and, in any case, at the latest within one month from the receipt of the request itself. This term may be extended by two months if necessary, taking into account the complexity and number of requests. The data controller informs the data subject of such extension and the reasons for the delay within one month from the receipt of the request.

According to paragraph 4 of the same article, the data controller, if it does not comply with the request of the data subject, “informs the data subject without delay, and at the latest within one month from the receipt of the request, of the reasons for non-compliance and the possibility of lodging a complaint with a supervisory authority and seeking judicial remedy.”

Article 15, paragraph 1, of the Regulation also states that “the data subject has the right to obtain from the data controller confirmation as to whether or not personal data concerning him or her are being processed and, if that is the case, to obtain access to the personal data and to [...] information [indicated in the same Article 15];

3. The assessments of the Authority and the outcome of the investigation.

Following the documentation produced and the statements made by the party during the proceedings, it is noted that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code. It has emerged that, in the case at hand, Intesa Sanpaolo S.p.a. did not respond to the request for access to personal data made by the complainant within the time frame provided by Article 12, paragraph 3 of the Regulation (“without undue delay and, in any case, at the latest within one month from the receipt of the request”), nor did it inform the applicant, within the same time frame, of the reasons for non-compliance as well as the possibility of lodging a complaint with a supervisory authority or seeking judicial remedy (Article 12, paragraph 4 of the Regulation).

Only following the submission of the complaint and the opening of the investigation did the Bank provide the data subject with the requested information, simultaneously detailing the circumstances that led to the aforementioned delay.

In particular, regarding the reasons identified by the Company as causes of its conduct (sending the access request to the general certified email address, different from the one specifically dedicated to

exercising rights regarding personal data protection), it is recalled that the “Guidelines 01/2022 on data subject rights - Right of access,” adopted by the EDPB on January 18, 2022, clarify that data subjects are not obliged to adopt a specific format to submit requests for exercising the right of access (see Guidelines 01/2022 cited, point 52 “the GDPR does not impose any requirements on data subjects regarding the form of the request for access to the personal data. Therefore, there are in principle no requirements under the GDPR that the data subjects must observe when choosing a communication channel through which they enter into contact with the controller” unofficial translation “the General Data Protection Regulation does not impose any requirements on data subjects regarding the format of the request for access to personal data. Therefore, in principle, there are no requirements that the data subject must comply with when choosing a communication channel through which to contact the data controller”).

4. Conclusions: declaration of unlawfulness of the processing. Corrective measures pursuant to Article 58, paragraph 2 of the Regulation.

For the aforementioned reasons, the Authority believes that the statements made by the data controller in the defensive memoranda - the truthfulness of which may be subject to liability under the aforementioned Article 168 of the Code - although deserving of consideration, do not allow overcoming the objections notified by the Office with the initiation of the proceedings and are insufficient to allow for its dismissal, as none of the cases provided for by Article 11 of the Guarantor's Regulation No. 1/2019, concerning internal procedures within the Authority having external relevance, apply.

The failure to respond in a timely manner to the request for access to personal data concerning the minor child made by the complainant is indeed unlawful, as stated above, for violation of Article 12, paragraphs 3 and 4 of the Regulation; on the other hand, regarding the request to “order the data controller to comply with the requests for exercising the rights referred to in Articles 15 to 22 of the Regulation,” considering that the Bank, as soon as it received the communication from the Authority and established the misunderstanding, provided the complainant with the requested information (also transmitting a copy of the banking documentation subsequently requested pursuant to Article 119, paragraph 4, of Legislative Decree No. 385/1993 - T.U.B. without applying the legally prescribed fees), there is no basis for the adoption of an injunction by the Authority itself (Article 58, paragraph 2, letters c) and d)).

Therefore, the complaint submitted pursuant to Article 77 of the Regulation must be considered well-founded, and this Authority, in exercising the corrective powers attributed to it pursuant to Article 58, paragraph 2, of the Regulation, orders the application of an administrative monetary penalty pursuant to Article 83, paragraph 5, of the Regulation.

5. Order of injunction.

The violation of the aforementioned provisions entails the application of the administrative sanction provided for by Article 83, paragraph 5, letter b), of the Regulation.

With reference to the elements listed in Article 83, paragraph 2, of the Regulation for the purpose of applying the administrative pecuniary sanction and its quantification, considering that the sanction must be “effective, proportionate, and dissuasive in each individual case” (Article 83, paragraph 1 of the Regulation), it is represented that, in this specific case, the following circumstances have been taken into account:

- a) the significant nature of the violation, which concerned the provisions related to the exercise of the rights of the data subjects;
- b) the degree of responsibility of the data controller, which is mitigated as they, upon becoming aware of the violation, provided the data subject with the requested information;
- c) the measures adopted by the data controller to mitigate the negative consequences arising from the unlawful act, including the free provision of the banking documentation subsequently requested by the data subject pursuant to Article 119 of the Consolidated Banking Act;
- d) the cooperation with the Authority during the proceedings;
- e) the small number of data subjects involved (one);

f) the organizational measures implemented by the data controller to avoid the failure to process a request for the exercise of rights that arrives at a structure other than the one with direct competence;
g) the fact that the data controller has already been the recipient of previous measures under Article 58 of the Regulation.

In consideration of the aforementioned principles of effectiveness, proportionality, and dissuasiveness (Article 83, paragraph 1, of the Regulation) to which the Authority must adhere in determining the amount of the sanction, the economic conditions of the offender have been taken into account, determined based on the revenues reported in the financial statements for the year 2022, and it has also been considered that the data controller has already been the recipient of measures under Article 58 of the Regulation.

In light of the aforementioned elements, evaluated in their entirety, it is deemed appropriate to determine the amount of the pecuniary sanction at €42,000 (forty-two thousand) for the violation of Article 12, paragraphs 3 and 4, of the Regulation.

In this context, also considering the type of violation established, which concerned the principles of personal data protection, it is deemed that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019, the publication of this measure on the Garante's website should proceed.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Garante, are met.

ALL OF THE ABOVE CONSIDERED, THE Garante declares, pursuant to Articles 57, paragraph 1, letter f) and 83 of the Regulation, the unlawfulness of the processing carried out, as stated in the reasoning, for the violation of Article 12, paragraphs 3 and 4, of the Regulation.

ORDERS

Intesa Sanpaolo S.p.a., with registered office in Turin, Piazza San Carlo, 156, VAT No. 11991500015, pursuant to Article 58, paragraph 2, letter i), of the Regulation, to pay the sum of €42,000 (forty-two thousand) as an administrative pecuniary sanction for the violations indicated in this measure;

COMMANDS

the same Intesa Sanpaolo S.p.a. to pay the sum of €42,000 (forty-two thousand) according to the methods indicated in the annex, within 30 days from the notification of this measure, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/1981. It is represented that pursuant to Article 166, paragraph 8 of the Code, the offender retains the option to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction within the deadline referred to in Article 10, paragraph 3, of Legislative Decree No. 150 of September 1, 2011, provided for the submission of the appeal as indicated below.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019, the publication of this measure on the Garante's website and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150 of September 1, 2011, an appeal against this measure may be filed before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the measure itself or within sixty days if the appellant resides abroad.

Rome, September 14, 2023

THE VICE PRESIDENT
Cerrina Feroni

THE REPORTER

Scorza

THE DEPUTY SECRETARY GENERAL

Filippi